

Network Device Compliance Report

Generated 2026-09-27 11:35

Device Name	fortinet_sample.cfg
Detected Vendor	Fortinet
Framework	CIS
Overall Compliance	71.4% (10/14 controls passed)
Failures by Severity	High: 1 Medium: 3 Low: 0

Compliance Findings

CIS-01	Telnet Disabled	High	PASS
--------	-----------------	------	------

Description: Telnet transmits credentials and session data in cleartext.
Evidence: set allowaccess https ssh http
Detected: Disabled
Expected: Telnet must be disabled. SSH should be used for remote administration.

CIS-02	SSH Version 2 Enforced	High	PASS
--------	------------------------	------	------

Description: SSHv1 has known cryptographic weaknesses; only SSHv2 should be permitted.
Evidence: set allowaccess https ssh http
Detected: 2
Expected: SSH version 2 must be the only version permitted.

CIS-03	HTTP Management Disabled	Medium	FAIL
--------	--------------------------	--------	------

Description: Unencrypted HTTP management exposes credentials and session data.
Evidence: set allowaccess https ssh http
Detected: Enabled
Expected: Unencrypted HTTP management must be disabled.
Why it matters: HTTP management sends credentials unencrypted. Any device on the management path can capture them.
Attack path: HTTP management enabled -> Admin logs in via web UI -> Credentials transmitted in cleartext -> Session cookie hijacked -> Attacker inherits admin session
Remediation:
config system interface
edit
set allowaccess https ssh
end
Turns off the unencrypted web admin interface; only HTTPS remains.

CIS-04	HTTPS Management Enabled	Medium	PASS
--------	--------------------------	--------	------

Description: Encrypted management access should be available as the secure alternative to HTTP.
Evidence: set allowaccess https ssh http
Detected: Enabled
Expected: Encrypted HTTPS management must be available.

CIS-05	Password Encryption Enabled	High	PASS
--------	-----------------------------	------	------

Description: Locally stored passwords must be encrypted, not stored in plaintext.
Evidence: (platform default: FortiOS stores admin passwords encrypted)
Detected: Enabled
Expected: Locally stored passwords must be encrypted, not stored in plaintext.

CIS-06	Minimum Password Length >= 8	Medium	PASS
--------	------------------------------	--------	------

Description: Weak minimum password length increases brute-force risk.
Evidence: set minimum-length 10
Detected: 10
Expected: Minimum password length must be at least 8 characters.

CIS-07	Login Banner Configured	Low	PASS
--------	-------------------------	-----	------

Description: A legal/warning banner should be presented before authentication.

Evidence: set pre-login-banner enable

Detected: Enabled

Expected: A legal/warning banner must be displayed before authentication.

CIS-08	Session Idle Timeout <= 10 min	Medium	FAIL
--------	--------------------------------	--------	------

Description: Idle admin sessions should time out to reduce hijack risk.

Evidence: set admintimeout 15

Detected: 15

Expected: Idle administrative sessions must time out within 10 minutes.

Why it matters: Idle sessions left open can be hijacked by someone with brief access to an unattended terminal.

Attack path: Admin leaves session unattended -> Session remains active -> Attacker uses live session -> Configuration changes made as admin

Remediation:

config system global

set admintimeout 10

end

Terminates an admin session after 10 minutes of inactivity.

CIS-09	Centralized Logging Enabled	High	PASS
--------	-----------------------------	------	------

Description: Administrative access and events must be logged for audit/forensics.

Evidence: set status enable

Detected: Enabled

Expected: Administrative and security events must be sent to a central syslog server.

CIS-10	NTP Configured	Medium	PASS
--------	----------------	--------	------

Description: Accurate time sync is required for reliable log correlation.

Evidence: set ntpsync enable

Detected: Enabled

Expected: NTP time synchronization must be configured.

CIS-11	Centralized Authentication (AAA) Configured	Medium	FAIL
--------	---	--------	------

Description: Authentication should be centralized (AAA/RADIUS/TACACS+), not local-only.

Evidence: No aaa configured configuration detected.

Detected: Not configured / not detected in this configuration.

Expected: Authentication must be centralized via AAA/RADIUS/TACACS+.

Why it matters: Local-only authentication means no central revocation and no consistent policy.

Attack path: Local-only authentication -> Employee leaves, credentials remain valid -> No central revocation -> Ex-employee retains access

Remediation:

config user radius

edit

set server

end

Enables centralized authentication via RADIUS/TACACS+ instead of local-only accounts.

CIS-12	Management Access Restricted via ACL	High	PASS
--------	--------------------------------------	------	------

Description: Administrative interfaces must be restricted to trusted source addresses.

Evidence: set trusthost1 10.0.0.0 255.255.255.0

Detected: Enabled

Expected: Administrative interfaces must be restricted to trusted source addresses.

CIS-13	No Default/Weak SNMP Community Strings	High	FAIL
--------	--	------	------

Description: Default community strings (public/private) allow unauthorized SNMP access.

Evidence: set name public

Detected: Enabled

Expected: SNMP community strings must not be the defaults (public/private).

Why it matters: Default SNMP community strings ('public'/'private') are known to every attacker.

Attack path: Default SNMP community in use -> Attacker scans with default strings -> Full device inventory disclosed -> Targeted exploitation

Remediation:

config system snmp community

edit 1

set name

end

Replaces the default 'public'/'private' SNMP community string with a strong custom one.

CIS-14

Account Lockout Policy Configured

Medium

PASS

Description: Repeated failed logins should trigger a lockout to slow brute-force attempts.

Evidence: set admin-lockout-threshold 3

Detected: Enabled

Expected: A login lockout policy must be configured.